

Hallazgos de análisis externo — ERSo 2026-008

- Hallazgos de análisis externo — ERSo 2026-008
 - Ciclo de vida y trazabilidad de versiones del DID Document
 - 1. Resumen
 - 2. Proyectos citados en este informe
 - 3. Hallazgos
 - 4. Aplicación a los criterios de aceptación de la ERSo 008
 - 5. Diferencias de diseño frente a nuestro proyecto
 - 6. Qué aprender y qué hacer con esto
 - 7. Límites de este informe

Hallazgos de análisis externo — ERSo 2026-008

Ciclo de vida y trazabilidad de versiones del DID Document

Proyecto propio	Identidad Digital Soberana SSI (/home/geovani/Descargas/generic/bitacora/new_proyect)
Fecha del análisis	2 de octubre de 2026
Carpetas analizadas	/home/geovani/Workspace/Wallet/Wallet , .../Verifier , .../Issuer , .../Trust , .../librerias
Versión del informe	Actualizado el 2 de octubre de 2026: se añaden los hallazgos de la carpeta librerias y el análisis a fondo del gestor de listas de confianza
Cobertura de esta ERSo	Parcial (historial en av-app-android-wallet-ui) y por analogía (diferida, notificación, baja y revocación)
Método	Lectura de código y documentación; no se compiló ni se ejecutó ninguno de los proyectos externos

1. Resumen

La ERSo 008 trata del ciclo de vida del documento: crear, actualizar, desactivar y reconstruir el estado en cada momento. En los proyectos externos solo el módulo VDR de av-app-android-wallet-ui conserva historial de documentos (con Git), y no tiene desafíos, versión esperada ni baja. Lo equivalente a "desactivar" aparece en la **revocación de credenciales** (Issuer/eudi-srv-pid-issuer , Issuer/eudi-srv-web-issuing-eudiw-py , Verifier/eudi-srv-statuslist-py , Wallet/eudi-app-android-wallet-ui) y en el estado granted/withdrawn de las listas de confianza (Trust/eudi-srv-web-trustedlist-manager-py , Verifier/eudi-wallet-rfcs). **Complemento:** del **gestor de listas de confianza** (número de secuencia, estados, certificados antiguos) y de la carpeta librerias : la emisión **diferida** de OpenID4VCI es el equivalente de nuestro estado pendiente, y el gestor de documentos modela estados y baja con constancia.

2. Proyectos citados en este informe

Carpeta	Proyecto	Qué es
Wallet	av-app-android-wallet-ui	App Android de verificación de edad (versión derivada de la anterior); incluye el módulo vdr-extension-logic
Issuer	eudi-srv-pid-issuer	Emisor de credenciales (Kotlin/Spring)
Issuer	eudi-srv-web-issuing-eudiw-py	Emisor web con revocación (Python/Flask)
Verifier	eudi-srv-statuslist-py	Servidor de listas de estado / revocación (Python)
Verifier	eudi-srv-verifier-endpoint	Backend verificador (Kotlin/Spring)
Wallet	eudi-app-android-wallet-ui	App Android de la cartera EUDI (referencia)
Trust	eudi-srv-web-trustedlist-manager-py	Gestor de Listas de Confianza (Python)
Verifier	eudi-wallet-rfcs	Especificaciones EWC (RFC 001 a 013)
librerias	eudi-lib-jvm-openid4vci-kt	Biblioteca de OpenID4VCI 1.0 (emisión, DPoP, attestation, diferida, notificación)
librerias	eudi-lib-android-wallet-document-manager	Gestor de documentos de la cartera (estados, políticas de credencial, claves)
librerias	eudi-lib-android-wallet-core	Biblioteca Android de la cartera EUDI: claves, documentos, confianza, estado, registro de transacciones
librerias	eudi-lib-kmp-statium	Biblioteca de listas de estado de tokens (draft 12)

3. Hallazgos

La columna *Criterio* indica a qué criterio de aceptación de la ERSO se aplica el hallazgo (el detalle está en la sección 4).

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Relación con nuestro proyecto	Criterio
1	Wallet/av-app-android-wallet-ui	vdr-extension-logic/.../registry/GitBackedRegistry.kt (history , resolve(did, atCommit))	history(did) lista los commits del DID, más reciente primero; resolve con atCommit devuelve el documento tal como estaba en esa versión. La prueba resolver una version anterior por commitId... lo comprueba.	Equivale a nuestro historial de versiones; ellos reconstruyen por commit, nosotros por instante (state?at=).	C7
2	Wallet/av-app-android-wallet-ui	.../registry/GitBackedRegistry.kt (register , update)	register falla si el DID ya existe (DidAlreadyRegisteredException); update falla si no existe (DidNotFoundException). Ambos son @Synchronized .	Control mínimo de existencia; no hay versión esperada (If-Match) ni idempotencia.	C4
3	Wallet/av-app-android-wallet-ui	.../routes/VdrRoutes.kt	No hay operación de baja (DEACTIVATE) ni estado terminal.	Nuestro VDR tiene desactivación explícita, estado terminal y 410 para el público.	C7
4	Wallet/av-app-android-wallet-ui	vdr-extension-logic/README.md	Declara la política de ciclo de vida y rotación (ERSO 008) como fuera de alcance; deja history y versionId como base técnica.	Confirma que ese módulo no cubre la ERSO 008 completa.	C7
5	Issuer/eudi-srv-pid-issuer	src/main/kotlin/.../port/out/status/AllocateStatus.kt; port/input/RevokeCredentialsWithRevokedStatus.kt; adapter/input/scheduler/CredentialRevocationJob.kt	Asigna un lugar en una lista de estado al emitir y revoca por trabajo programado (issuer.revocation.job.cron) cuando el estado deja de ser válido.	Revocación equivale a nuestra desactivación: algo emitido deja de valer.	C7
6	Issuer/eudi-srv-web-issuing-eudiwpy	app/revocation.py; app/nightly_status_sweep.py	Revocación iniciada por el usuario con prueba (OpenID4VP) y barrido nocturno de estados.	Segundo mecanismo de baja, con prueba de quien la pide.	C2, C7
7	Verifier/eudi-srv-statuslist-py	app/status_list_endpoints.py (/take , /get , /set)	Servicio de listas de estado con clave de API (X-API-Key); en /get la comprobación de la clave está comentada.	Otro registro con operaciones autenticadas; la rama comentada es un ejemplo de lo que no se debe copiar.	C1
8	Verifier/eudi-srv-verifier-endpoint	.../adapter/out/tokenstatuslist/StatusListTokenValidator.kt (línea ~116)	verifyStatusListTokenSignature = { _, _ -> Result.success(Unit) } : la rama del token de estado no se verifica en esta configuración.	Ejemplo de límite de seguridad de una configuración de prueba.	C5
9	Wallet/eudi-app-android-wallet-ui Wallet/av-app-android-wallet-ui	core-logic/.../worker/RevocationWorkManager.kt	Trabajo periódico de la cartera que consulta el estado de las credenciales y notifica las revocadas (Invalid o Suspended).	Equivalente de la cartera a lo que haría un cliente que vigile la desactivación de un DID.	C7

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Relación con nuestro proyecto	Criterio
10	Trust/eudi-srv-web-trustedlist-manager-py	app/xml_gen/xmlGen_List.py; app/RPR_routes.py (/tsl/create , /tsl/edit)	Las listas de confianza se crean, editan, firman y publican.	Un servicio retirado de la lista (withdrawn) es el equivalente a un DID desactivado.	C7
11	Verifier/eudi-wallet-rfcs	ewc-rfc012-trust-mechanism.md (§4.2.2)	Estados de servicio granted y withdrawn.	Referencia del estado terminal en el mundo de listas de confianza.	C7
12	Issuer/eudi-srv-pid-issuer	application.properties (duration=P31D) y .../port/out/persistence/DeleteExpiredIssuedCredentials.kt	Vigencia de 31 días y borrado de las caducadas.	Nuestro DID no caduca por tiempo.	C7
13	librerias/eudi-lib-jvm-openid4vci-kt	src/main/kotlin/.../openid4vci/DeferredIssuer.kt y QueryForDeferredCredential.kt; README ("Query for deferred credentials")	Si el emisor no puede entregar la credencial de inmediato responde con un identificador de transacción y la cartera la consulta después (inmediatamente o más tarde).	Equivale a nuestro estado PENDING con reconciliación posterior (criterio 6).	C6
14	librerias/eudi-lib-jvm-openid4vci-kt	.../openid4vci/NotifyIssuer.kt	La cartera notifica al emisor si aceptó o falló la credencial.	Confirmación en sentido inverso; en nuestro caso el registro confirma leyendo su propia URL.	C5
15	librerias/eudi-lib-jvm-openid4vci-kt	.../openid4vci/internal/http/NonceEndpointClient.kt y GetAbcaChallengeAndDPoPNonce.kt	Nonce de un solo uso para la prueba y nonce de DPoP.	Equivale a nuestro desafío de un solo uso (criterio 2).	C2
16	librerias/eudi-lib-android-wallet-document-manager	document-manager/.../Document.kt, UnsignedDocument.kt, DeferredDocument.kt, IssuedDocument.kt	Estados del documento: sin firmar, diferido y emitido (interfaz sellada Document).	Máquina de estados de la credencial; análoga al ciclo de vida de nuestro DID.	C7
17	librerias/eudi-lib-android-wallet-document-manager	document-manager/.../DocumentManager.kt (deleteDocumentById)	La baja devuelve Outcome<ProofOfDeletion?> : una constancia de eliminación .	Equivale a la evidencia de nuestra desactivación (versión de baja con el hash del último documento).	C7
18	librerias/eudi-lib-android-wallet-core	wallet-core/.../transactionLogging/ (TransactionLogManager, TransactionLogExport)	Registro y exportación del historial de transacciones.	Trazabilidad del lado de la cartera (criterio 7).	C7
19	librerias/eudi-lib-kmp-stadium	eudi-lib-kmp-stadium (README, Types.kt)	Estados Valid, Invalid y Suspended en listas de estado (draft 12); Suspended es reversible.	Nuestra baja es terminal; el estado suspendido sería una extensión posible.	C7

#	Proyecto (carpeta/proyecto)	Archivo o lugar	Qué se encontró	Relación con nuestro proyecto	Criterio
20	librerias/eudi-lib-android-wallet-core	wallet-core/.../statium/DocumentStatusResolver.kt	Resuelve el estado de los documentos emitidos.	Lectura periódica del estado de lo emitido.	C7
21	Trust/eudi-srv-web-trustedlist-manager-py	app/xml_gen/xmlGen.py y app/script_db.sql (service_status_history , lotl_old_certificates)	Cada servicio tiene estado y fecha de inicio; se guarda el estado anterior y los certificados de firma antiguos.	Historial de estados y de claves de firma: parecido a conservar todas las versiones, pero sin consulta por instante.	C7

4. Aplicación a los criterios de aceptación de la ERSO 008

Para cada criterio: lo que exige el PDF de la ERSO, dónde está nuestra evidencia y qué hallazgos externos se le aplican.

Criterio 1. Las precondiciones se cumplen; si alguna falla no se emite desafío.

Evidencia que pide la ERSO	Verificación de cuenta y canal.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-008 §17
Hallazgos aplicables	#7 (Verifier/eudi-srv-statuslist-py)
Qué aporta el análisis	Solo se halló una clave de API en el servicio de listas de estado, con la comprobación comentada en una ruta.

Criterio 2. El desafío es de un solo uso, con tipo y audiencia específicos.

Evidencia que pide la ERSO	Registro de emisión del desafío.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-008 §18
Hallazgos aplicables	#6 (Issuer/eudi-srv-web-issuing-eudiw-py); #15 (librerias/eudi-lib-jvm-openid4vci-kt)
Qué aporta el análisis	La revocación iniciada por el usuario exige una prueba por OpenID4VP; no se halló un desafío con tipo y audiencia como el nuestro. Las bibliotecas de emisión usan nonces de un solo uso, igual que nuestro desafío.

Criterio 3. El documento no incluye claves privadas y el id y los controladores corresponden al recurso autorizado.

Evidencia que pide la ERSO	Documento de la operación.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-008 §19
Hallazgos aplicables	Ninguno
Qué aporta el análisis	No se encontró nada aplicable en los proyectos externos.

Criterio 4. La escritura exige la versión esperada y devuelve versión, hash y URL pública.

Evidencia que pide la ERSO	Respuesta del registro.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-008 §20
Hallazgos aplicables	#2 (Wallet/av-app-android-wallet-ui)
Qué aporta el análisis	El único registro externo solo controla existencia al registrar y actualizar; no hay versión esperada ni idempotencia.

Criterio 5. La publicación se confirma por lectura de la URL y comparación de hash.

Evidencia que pide la ERSO	Comparación de contenido y hash.
Nuestra evidencia	INFORME-FINAL-ERSO-2026-008 §21
Hallazgos aplicables	#8 (Verifier/eudi-srv-verifier-endpoint); #14 (librerias/eudi-lib-jvm-openid4vci-kt)
Qué aporta el análisis	Por analogía, el verificador consulta listas de estado; en su configuración la firma del token de estado no se verifica.

Criterio 6. Si no hay respuesta en plazo, la operación queda pendiente y no se da por publicada.

Evidencia que pide la ERSo	Estado de la operación.
Nuestra evidencia	INFORME-FINAL-ERSo-2026-008 §22
Hallazgos aplicables	#13 (librerias/eudi-lib-jvm-openid4vci-kt)
Qué aporta el análisis	No se encontró nada aplicable en los proyectos externos. La emisión diferida de OpenID4VCI es un estado pendiente que se resuelve consultando más tarde.

Criterio 7. La traza permite reconstruir el estado en cada momento.

Evidencia que pide la ERSo	Historial de versiones.
Nuestra evidencia	INFORME-FINAL-ERSo-2026-008 §23
Hallazgos aplicables	#1 (Wallet/av-app-android-wallet-ui); #3 (Wallet/av-app-android-wallet-ui); #4 (Wallet/av-app-android-wallet-ui); #5 (Issuer/eudi-srv-pid-issuer); #6 (Issuer/eudi-srv-web-issuing-eudiw-py); #9 (Wallet/eudi-app-android-wallet-ui , Wallet/av-app-android-wallet-ui); #10 (Trust/eudi-srv-web-trustedlist-manager-py); #11 (Verifier/eudi-wallet-rfcs); #12 (Issuer/eudi-srv-pid-issuer); #16 (librerias/eudi-lib-android-wallet-document-manager); #17 (librerias/eudi-lib-android-wallet-document-manager); #18 (librerias/eudi-lib-android-wallet-core); #19 (librerias/eudi-lib-kmp-statium); #20 (librerias/eudi-lib-android-wallet-core); #21 (Trust/eudi-srv-web-trustedlist-manager-py)
Qué aporta el análisis	Criterio con más material: historial por commits con resolución de una versión anterior, revocación programada de credenciales, listas de confianza con estados granted y withdrawn, y vigencia de las credenciales.

5. Diferencias de diseño frente a nuestro proyecto

Tema	Proyectos externos	Nuestro proyecto
Historial	Commits de Git (av-app-android-wallet-ui)	Tabla de versiones de solo-agregar con disparadores
Actualización concurrente	@Synchronized	If-Match + bloqueo de la fila del DID
Reintentos	Sin control	Idempotency-Key
Baja	No existe en av-app-android-wallet-ui ; en emisores, revocación por lista de estado	DEACTIVATE terminal (409 TERMINAL_STATE , 410 público)
Confirmación de publicación	No existe	Lectura de la URL y comparación de hash; PENDING y reconciliación
Prueba de posesión	No existe	Desafío de un solo uso firmado con la clave vigente

6. Qué aprender y qué hacer con esto

- Estudiar `GitBackedRegistry` para ver una forma alternativa y sencilla de trazabilidad; luego contrastar con nuestras garantías (inalterabilidad por disparadores).
- Las listas de estado son la referencia para una futura revocación de credenciales; nuestro proyecto no la implementa.
- Para la defensa: las advertencias de la ERSo 008 (rotación sin validación histórica y recuperación por pérdida de clave) no están resueltas en ninguno de los proyectos externos.
- Cuidado con copiar configuraciones de prueba que omiten verificaciones (firma del token de estado, clave de API comentada).
- Para la defensa del criterio 6: la credencial diferida es el equivalente estandarizado de una operación pendiente que se reconcilia después.
- Idea futura: un estado suspendido (reversible) además de la baja terminal, como contempla la especificación de listas de estado.
- Del gestor de listas de confianza: guardar los certificados de firma anteriores es una buena práctica para poder verificar documentos antiguos (la advertencia de la ERSo 008 sobre validación histórica).

7. Límites de este informe

- Todo proviene de **lectura de código**; el comportamiento real no se verificó ejecutando.
- Se citan archivos y, cuando se anotó, números de línea (con ~ si son aproximados); las versiones de los proyectos son las que había en disco el 2 de octubre de 2026.
- "No encontré" significa que las búsquedas realizadas no lo hallaron, no que no exista en ninguna parte del código.
- Los proyectos de referencia EUDI se declaran a sí mismos como versiones de desarrollo no aptas para producción.